Правила Snort для обнаружения атак

Структура правил Snort

```
[action] [protocol] [sourceIP] [sourceport] -> [destinationIP] [destinationport]
([rule options])
```

1. Правило обнаружения сканирования портов

1.1. Правило

```
alert tcp any any -> 10.0.1.254 any (msg:"DEMO LAB - Possible Port Scan Detected";
flags:S; detection_filter: track by_src, count 10, seconds 3; classtype:attempted-
recon; sid:1000001; rev:1;)
```

Описание:

Правило обнаруживает сканирование портов. Срабатывает, когда с одного IP-адреса за 3 секунды приходит 10 и более TCP-пакетов с флагом SYN (попытки установить соединение). Это как правило является признаком разведки перед атакой

Команда для проверки:

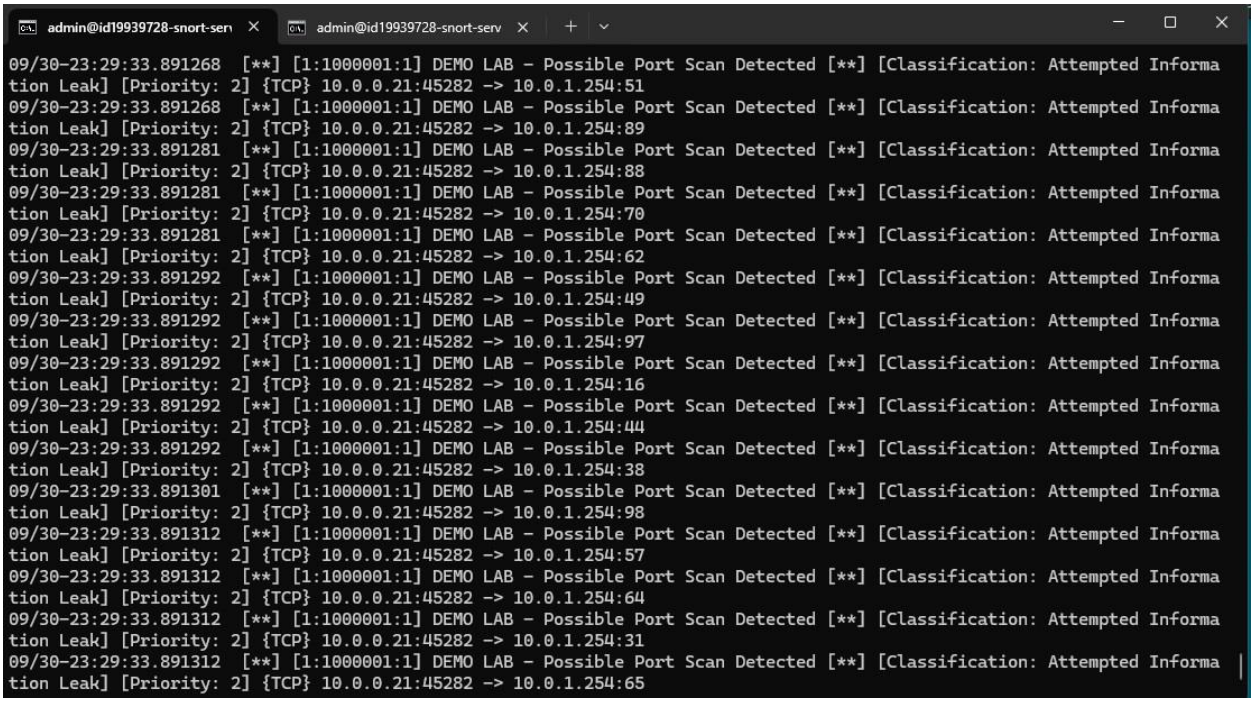
На snort-server:

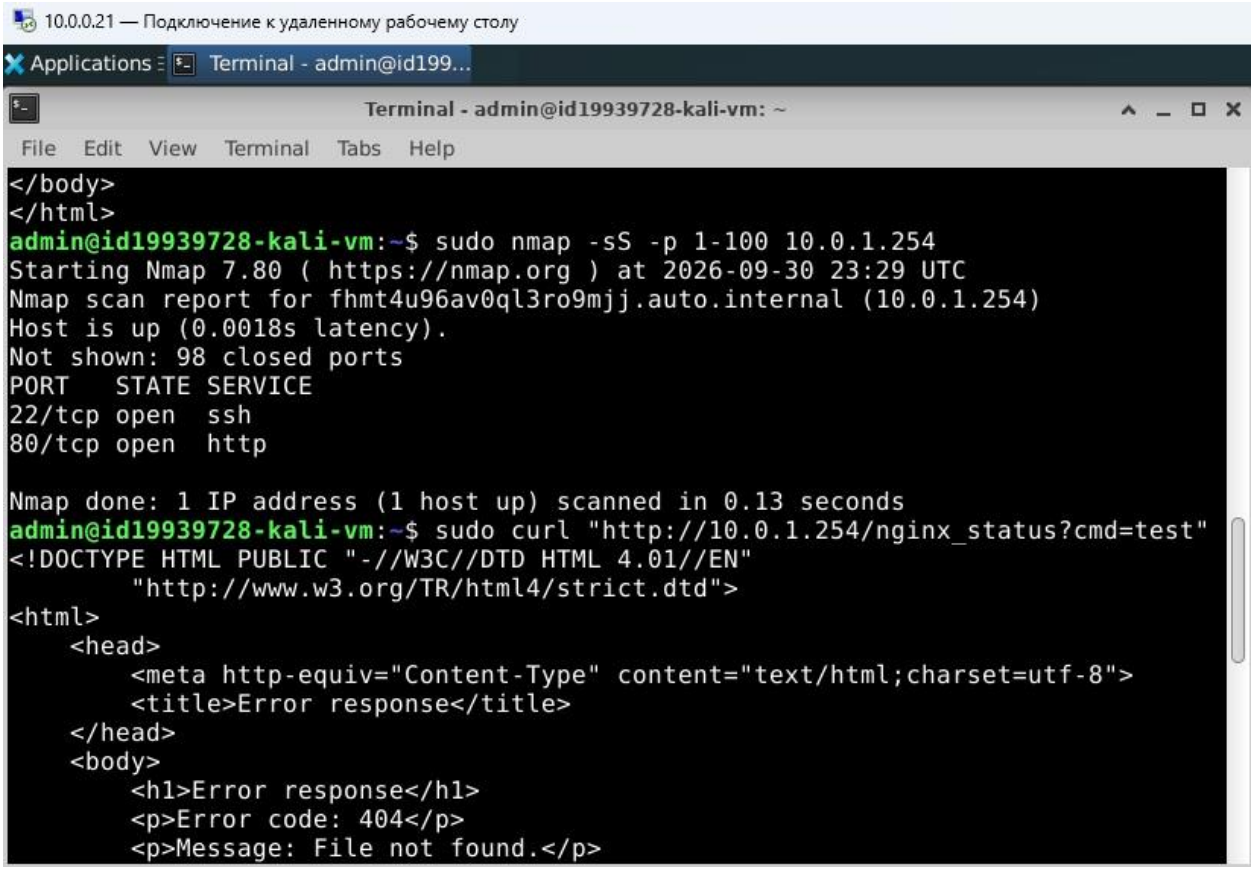
sudo snort -c /etc/snort/snort.conf -A console -i eth0

На Kali (с которого атакуем):

sudo nmap -sS -p 1-100 10.0.1.254

Результат (скриншот):





1.2. Правило обнаружения командной инъекции через Nginx

Правило:

alert tcp any any -> 10.0.1.254 80 (msg:"DEMO LAB - Nginx Command Injection Attempt"; pcre:"/nginx_status.*cmd=/"; classtype:web-application-attack; sid:1000002; rev:1;)

Описание:

Правило обнаруживает попытку эксплуатации веб-приложения через передачу параметра cmd= в URL вместе с обращением к служебному эндпоинту /nginx_status. Такая конструкция характерна для command injection — злоумышленник пытается выполнить произвольные команды на сервере

Команда для проверки:

На snort-server:

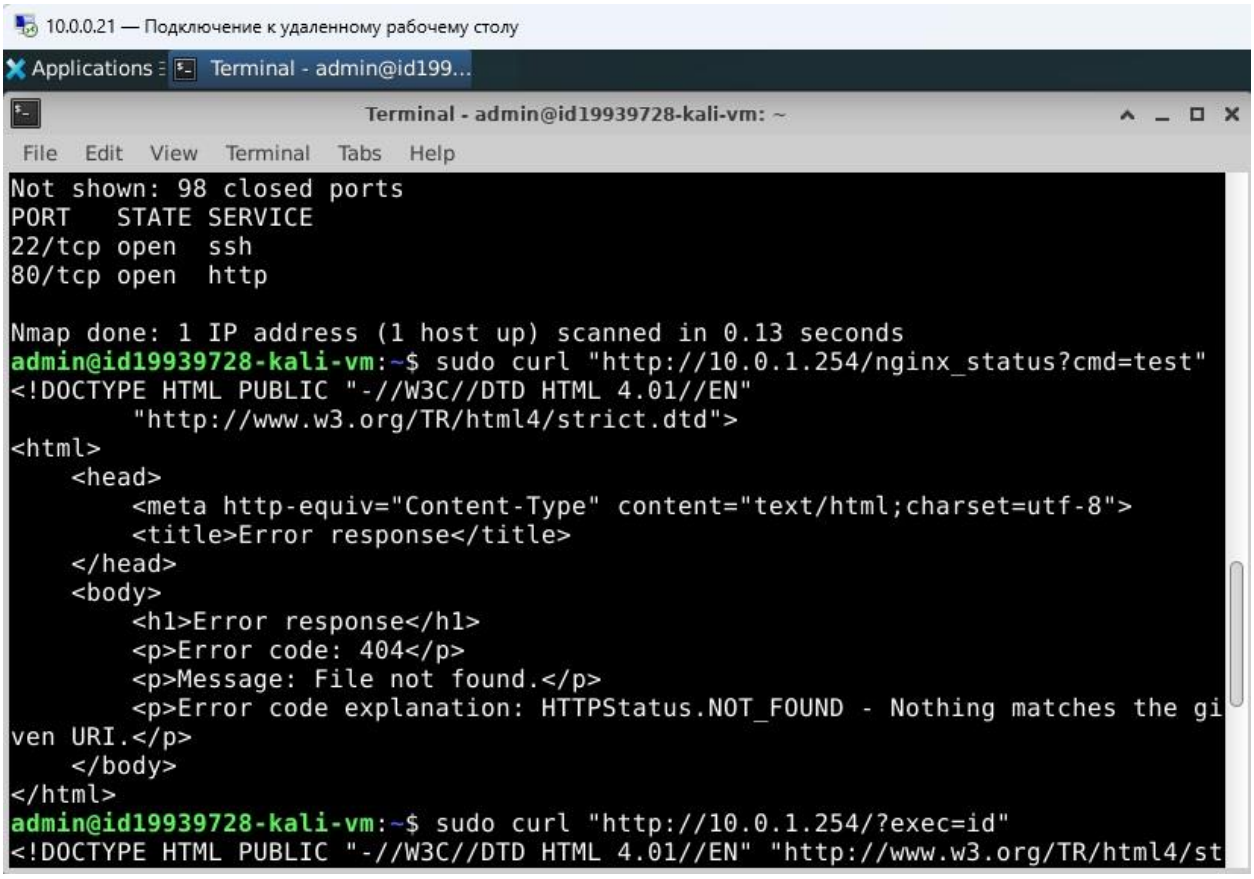
sudo snort -c /etc/snort/snort.conf -A console -i eth0

На Kali (с которого атакуем):

curl "http://10.0.1.254/nginx_status?cmd=test"

Результат (скриншот):

```
pplication Attack] [Priority: 1] {TCP} 10.0.0.21:56334 -> 10.0.1.254:80
09/30-23:30:21.146913  [**] [1:1000002:1] DEMO LAB - Nginx Command Injection Attempt [**] [Classification: Web Applicati
on Attack] [Priority: 1] {TCP} 10.0.0.21:56334 -> 10.0.1.254:80
```



1.3. Правило - универсальное обнаружение command injection

Правило:

```
alert tcp any any -> 10.0.1.254 80 (msg:"Possible command injection attempt in HTTP
request"; pcre:"/(cmd|exec|command|shell)=/Ui"; classtype:web-application-attack;
sid:1000101; rev:1;)
```

Описание:

Правило универсально ловит попытки command injection в HTTP-запросах через любой из типичных параметров: cmd=, exec=, command=, shell=

Команда для проверки:

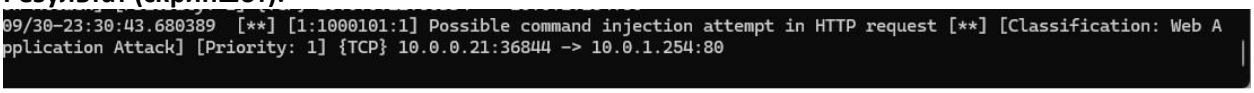
На snort-server:

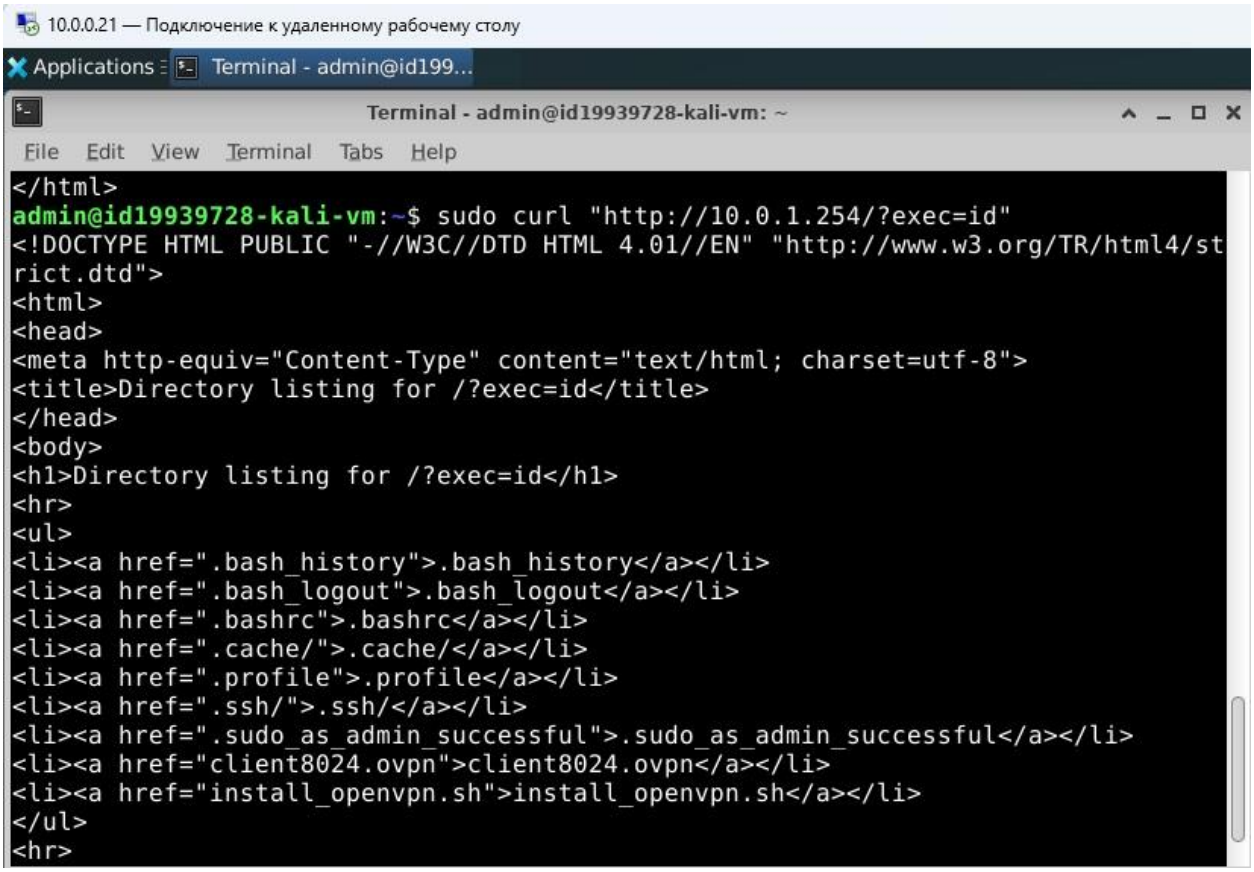
sudo snort -c /etc/snort/snort.conf -A console -i eth0

На Kali:

curl "http://10.0.1.254/?exec=id"

Результат (скриншот):





Все три правила:

```
Snort exiting
admin@id19939728-snort-server:~$ sudo cat /etc/snort/rules/local.rules
alert tcp any any -> 10.0.1.254 any (msg:"DEMO LAB - Possible Port Scan Detected"; flags:S; detection_filter: track by_src, count 10, seconds 3; classtype:attempted-recon; sid:1000001; rev:1;)

alert tcp any any -> 10.0.1.254 80 (msg:"DEMO LAB - Nginx Command Injection Attempt"; pcre:"/nginx_status.*cmd=/"; classtype:web-application-attack; sid:1000002; rev:1;)

alert tcp any any -> 10.0.1.254 80 (msg:"Possible command injection attempt in HTTP request"; pcre:"/(cmd|exec|command|shell)=/Ui"; classtype:web-application-attack; sid:1000101; rev:1;)
admin@id19939728-snort-server:~$
```